

VULNERABILITY ASSESSMENT REPORT

Passive Analysis Only · Read-Only Assessment · No Exploitation Performed

Target	testphp.vulnweb.com
Date	February 26, 2026
Classification	Confidential
Analysis Type	Passive / Read-Only — No exploitation performed
Prepared by	Security Assessment Team — Future Intern Programme

2 HIGH RISK Immediate action	2 MEDIUM RISK Planned remediation	0 LOW RISK Monitor	4 TOTAL All severities
---	--	---	---

4 findings identified across 2 categories

All remediable through standard server-side configuration changes

TOOLS USED

- NMAP 7.x
- OWASP ZAP v2.17
- BROWSER DEVTOOLS

1. Executive Summary

This report presents the findings of a passive security assessment conducted against the publicly accessible web application hosted at testphp.vulnweb.com. The assessment was limited to non-intrusive, read-only observation techniques designed to identify security weaknesses without affecting the availability or integrity of the target system.

A total of four findings were identified: two rated High severity and two rated Medium severity. No exploitation was performed and no systems were modified during the assessment. The most significant concerns relate to the absence of encrypted communication (HTTPS) and missing HTTP security headers — both well-established, baseline industry controls expected of any public-facing web application.

All findings identified in this report can be addressed through standard server-side configuration changes. No significant development effort or architectural restructuring is required to remediate the issues described. Immediate action is recommended on High-severity findings.

2. Scope & Ethical Considerations

This assessment was conducted exclusively using passive, read-only analysis techniques. No malicious payloads were injected, no authentication mechanisms were tested or bypassed, and no data was modified on the target server at any point.

Target	http://testphp.vulnweb.com (public demo site maintained by Acunetix)
Assessment Type	Passive, read-only observation — no exploitation performed
Pages in Scope	Publicly accessible pages only (no authenticated endpoints tested)
Out of Scope	Internal network, admin panels, third-party services, APIs requiring auth
Testing Period	February 26, 2026
Tools Used	Nmap (passive), OWASP ZAP (passive mode), Browser DevTools

The following activities were explicitly excluded from this assessment:

- No login bypass or authentication testing of any kind
- No brute-force or credential-guessing attempts
- No denial-of-service or stress testing
- No exploitation of any identified weaknesses
- No modification of server data or configuration
- All observations based solely on publicly visible HTTP responses

3. Methodology

The assessment followed a structured, three-phase passive reconnaissance approach. Each phase employed a specific tool to gather observable security information without sending malicious or intrusive payloads to the target system.

PHASE 1	PHASE 2	PHASE 3
Port & Service Discovery Nmap 7.x Port and service version detection using passive flags (-sV, -Pn). Identified 16 ports scanned; only port 80 (HTTP/nginx 1.19.0) was found open. Port 443 (HTTPS) was confirmed closed.	HTTP Header Analysis Browser DevTools HTTP response header inspection via the Network tab. A standard read-only technique used to identify missing security headers and information disclosure without sending any crafted requests.	Automated Passive Scan OWASP ZAP v2.17.0 Configured in passive scan mode only. Application responses were observed; no attack payloads were injected at any stage. ZAP identified 8 passive alerts across Medium, Low, and Informational levels.

4. Risk Rating Model

Findings are classified using a three-tier risk model aligned with OWASP Risk Rating Methodology and CVSS v3.1. Risk level is determined by combining the likelihood of exploitation with the potential business impact.

LEVEL	DEFINITION	EXPECTED RESPONSE
HIGH	A weakness that could directly lead to unauthorised access, data exposure, or service disruption. The potential business impact is significant.	Immediate — within 30 days
MEDIUM	A weakness that provides an attacker with information or capability that meaningfully increases the likelihood or impact of a future attack.	Planned — within 60-90 days
LOW	A weakness with limited standalone impact. May contribute to a broader attack chain if combined with other findings, but carries low urgency on its own.	Next maintenance cycle

F1

Unencrypted HTTP Communication

HIGH RISK

MAN-IN-THE-MIDDLE

NMAP — PHASE 1

DESCRIPTION

The web application communicates exclusively over HTTP on port 80. No HTTPS equivalent was detected on port 443, which was found closed during the port scan. This means all data exchanged between a visitor's browser and the server — including form submissions, session cookies, and sensitive user information — is transmitted as plain, unencrypted text over the network.

BUSINESS IMPACT

Any visitor accessing this website over an unsecured network — such as shared Wi-Fi, a hotel hotspot, or a corporate proxy — is at risk of having their data observed by an unauthorised third party. For a business, this represents a reputational risk, potential liability under data protection regulations such as GDPR, and a measurable loss of customer trust. Modern browsers also display a 'Not Secure' warning for HTTP-only sites, which can actively deter visitors.

POTENTIAL WEB ATTACK SCENARIO

Potential Attack (MITM): An attacker positioned on the same network as a website visitor — for example, a shared coffee shop or hotel Wi-Fi — could intercept and read the unencrypted HTTP traffic in real time. This would allow them to capture submitted form data, steal session cookies to impersonate logged-in users, or silently alter the content being displayed.

This Man-in-the-Middle attack requires only widely available tools and does not demand a high level of technical expertise.

RECOMMENDATION

Obtain and install a valid SSL/TLS certificate on the web server. Free certificates are available from Let's Encrypt (letsencrypt.org). Once installed, configure the server to redirect all HTTP traffic to HTTPS automatically and add an HSTS header to ensure browsers always connect securely. Nginx: add 'return 301 https://\$host\$request_uri;' to the HTTP server block.

F2

Multiple Missing HTTP Security Headers

HIGH RISK

XSS / CLICKJACKING / SSL STRIP

DEVTOOLS + ZAP — PHASE 2 & 3

DESCRIPTION

The server's HTTP responses do not include three critical security headers considered baseline controls by industry standards (OWASP, Mozilla Observatory). The absent headers are: (1) Content-Security-Policy (CSP) — not set, (2) X-Frame-Options — not set, and (3) Strict-Transport-Security (HSTS) — not set. Each header addresses a distinct, well-documented attack vector. Their collective absence indicates that standard web security hardening has not been applied to this server configuration.

BUSINESS IMPACT

The combined absence of these headers leaves the application exposed to three separate attack categories simultaneously. From a business perspective, successful exploitation could result in visitors being presented with injected malicious content, sessions being hijacked, or the website being used as a vehicle for attacks against its own users. Each of these outcomes carries significant reputational, legal, and operational risk for the business.

POTENTIAL WEB ATTACK SCENARIO

Three distinct scenarios apply: (1) XSS — Without CSP, an attacker who locates a content injection point could execute malicious scripts in a visitor's browser, stealing data or redirecting users to a fraudulent site. (2) Clickjacking — Without X-Frame-Options, the website can be embedded within a malicious page, tricking visitors into clicking hidden buttons or performing unintended actions. (3) SSL Stripping — Without HSTS, an attacker may attempt to downgrade a connection from HTTPS back to HTTP, bypassing encryption entirely.

RECOMMENDATION

Add all three headers to every HTTP response served by the application. Recommended values: Strict-Transport-Security: max-age=31536000; includeSubDomains — Content-Security-Policy: default-src 'self' — X-Frame-Options: DENY. These can be added as global response headers in the nginx configuration using the `add_header` directive, ensuring they apply to all pages without requiring any application code changes.

F3

Server and Technology Version Disclosure

MEDIUM RISK INFORMATION DISCLOSURE NMAP + DEVTOOLS — PHASE 1 & 2

DESCRIPTION

Two HTTP response headers return specific version information about the server's technology stack. The 'Server' header discloses the exact web server software version (nginx 1.19.0), and the 'X-Powered-By' header discloses the PHP runtime version (PHP 5.6.40). Both headers are returned by default server configurations and require no special effort to observe. Additionally, PHP 5.6 reached its official end-of-life in December 2018 and no longer receives security patches from the PHP development team.

BUSINESS IMPACT

Disclosing specific software versions allows an attacker to quickly cross-reference the server against publicly documented vulnerability databases and identify whether known, unpatched security flaws apply to these exact versions. While this observation alone is not an active attack, it meaningfully reduces the effort required for a targeted attack. The continued use of an unsupported PHP version also means the server may contain security flaws that cannot be patched without upgrading.

POTENTIAL WEB ATTACK SCENARIO

Potential Attack (Information Disclosure): An attacker who observes the 'Server: nginx/1.19.0' and 'X-Powered-By: PHP/5.6.40' headers can cross-reference these versions against public vulnerability databases (CVE, NVD) in seconds. They may then identify applicable known vulnerabilities and use available proof-of-concept tools to attempt exploitation, substantially reducing the time and skill required. This is a common early-stage step in reconnaissance-driven attacks.

RECOMMENDATION

Disable version disclosure in both nginx and PHP. In nginx, set 'server_tokens off;' in nginx.conf. In PHP, set 'expose_php = Off' in php.ini. Additionally, upgrade PHP to a currently supported version — PHP 8.2 or later is recommended. Review all server dependencies for end-of-life status as part of this upgrade cycle.

F4

Absence of CSRF Protection on Forms

MEDIUM RISK

CROSS-SITE REQUEST FORGERY

OWASP ZAP — PHASE 3

DESCRIPTION

The web application contains HTML forms that do not include Anti-CSRF (Cross-Site Request Forgery) tokens. CSRF tokens are unique, unpredictable values embedded in each form that verify a submission originated from the legitimate user and not from an external, malicious source. Their absence was detected on the application's form submission endpoints during passive observation of the page source.

BUSINESS IMPACT

Without CSRF protection, a visitor who is authenticated in the application and simultaneously visits a malicious website could have actions performed on their behalf without their knowledge or consent. For an application handling user accounts, contact forms, or any data-modifying operations, this could lead to unauthorised changes to user data or account settings without the user's awareness.

POTENTIAL WEB ATTACK SCENARIO

Potential Attack (CSRF): An attacker could craft a malicious webpage that, when visited by an authenticated user of the target application, silently submits a form request to the target server in the background. Because the browser automatically includes the user's session cookie with the request, the server processes it as a legitimate, user-initiated action. The user would be entirely unaware that any action was performed on their behalf.

RECOMMENDATION

Implement CSRF token generation and validation on all state-changing form submissions. Most web frameworks (Laravel, Django, Rails, etc.) include built-in CSRF protection that can be enabled with minimal configuration. Tokens should be unique per user session and validated server-side on every POST, PUT, PATCH, and DELETE request.

6. Additional ZAP Passive Scan Observations

The following lower-severity observations were recorded during the ZAP passive scan phase. They do not warrant standalone findings but are included for completeness and should be addressed during routine maintenance.

ALERT	RISK LEVEL	OBSERVATION & SUGGESTED ACTION
X-Content-Type-Options Missing	LOW	Add 'X-Content-Type-Options: nosniff' to prevent MIME-type sniffing by browsers.
Charset Mismatch (Header vs Meta)	INFORMATIONAL	HTTP header declares UTF-8 but HTML meta declares iso-8859-2. Align both declarations to avoid encoding inconsistencies.
Modern Web Application Detected	INFORMATIONAL	ZAP identified patterns consistent with a modern JavaScript framework. No action required; informational only.
Anti-clickjacking (duplicate)	MEDIUM	Addressed under Finding F2 (X-Frame-Options). No separate remediation required beyond that finding's recommendation.
CSP Header (duplicate note)	MEDIUM	Addressed under Finding F2 (Content-Security-Policy). No separate remediation required.

7. Remediation Priority Table

The table below provides a consolidated action plan ordered by remediation priority. Immediate actions should be scheduled within 30 days; planned actions within 60-90 days.

#	Finding	Risk	Primary Action	Effort	Priority
F1	Unencrypted HTTP Communication	HIGH	Install SSL/TLS cert; enforce HTTPS redirect; add HSTS header	Low	Immediate
F2	Multiple Missing HTTP Security Headers	HIGH	Add HSTS, CSP, X-Frame-Options via nginx add_header directives	Low	Immediate
F3	Server & PHP Version Disclosure	MEDIUM	Set server_tokens off; expose_php=Off; upgrade PHP to 8.2+	Low	Planned
F4	Absence of CSRF Protection on Forms	MEDIUM	Enable framework-native CSRF middleware on all form endpoints	Low-Med	Planned

8. Conclusion

This assessment identified four security findings across testphp.vulnweb.com, all of which can be resolved through standard server-side configuration changes. No finding requires significant development effort or architectural restructuring.

The two High-severity findings — unencrypted HTTP communication and missing security headers — should be treated as a priority. Both are addressable through nginx configuration changes and the addition of a free SSL/TLS certificate from Let's Encrypt. Both represent widely expected baseline controls for any publicly accessible website in 2026, and their absence may already be flagged by modern browsers displaying 'Not Secure' warnings to visitors.

The two Medium-severity findings — version disclosure and absent CSRF tokens — carry meaningful but lower immediate risk. They should be scheduled for remediation within 60-90 days as part of a planned security hardening cycle.

Following remediation, it is recommended to verify changes using a re-scan with OWASP ZAP and the Mozilla Observatory to confirm all findings have been successfully addressed. Periodic reassessments every 6-12 months are recommended as part of an ongoing security maintenance programme.

DISCLAIMER

This report was produced for educational and professional development purposes as part of the Future Intern Programme. The target (testphp.vulnweb.com) is a publicly available, intentionally vulnerable demonstration site maintained by Acunetix for security training. All findings reflect real-world security patterns applicable to production environments.